

DOCUMENT CONTROL

Prepared By	Tauqeer Mustafa Inc.
Version	2.0
Effective Date	05/06/2026
Review Date	05/06/2027
Classification	CONFIDENTIAL
Framework	NIST Cybersecurity Framework 2.0 NIST SP 800-63B
Approved By	Dept. Of CYS - Tauqeer Mustafa Inc.

EXECUTIVE SUMMARY

- 1. Purpose:** This policy establishes mandatory baseline security controls for **BTOs Corp.** to protect client data, financial records, and operational systems from unauthorized access, data breaches, and operational disruption.

2. Scope: All employees, contractors, and authorized third parties who access, process, or store company information assets are bound by this policy, regardless of device or location.

3. Enforcement: Non-compliance may result in disciplinary action up to and including termination of employment or contract. All personnel must acknowledge this policy annually.

INFORMATION SECURITY POLICY

SME

1. Purpose & Scope

1.1 Purpose

This Information Security Policy establishes the baseline security requirements for **BTOs Corp.** to protect the confidentiality, integrity, and availability of its information assets, client data, financial records, and operational systems. This policy exists to minimize the risk of data breaches, unauthorized access, and operational disruptions that could result in financial loss, regulatory penalties, or reputational damage.

1.2 Scope

This policy applies to all employees, contractors, consultants, and authorized third-party vendors who access, process, store, or transmit **BTOs Corp.** information assets. It covers all information

systems, devices, networks, and cloud platforms used for business operations, regardless of ownership or physical location.

1.3 Enforcement

Violations of this policy may result in disciplinary action, revocation of system access, or termination of employment or contract. Executive management reserves the right to conduct periodic compliance audits. All employees must acknowledge this policy upon commencement of employment and at each annual review.

2. Definitions

The following terms are used throughout this policy:

- **Information Asset:** Any data, system, software, hardware, or network resource that has value to the organization and must be protected against unauthorized access, modification, or destruction.
- **Confidential Data:** Information classified as sensitive, including but not limited to client financial records, contracts, authentication credentials, payroll data, and legal documents. Unauthorized disclosure may result in legal liability or financial harm.
- **PII (Personally Identifiable Information):** Any data that can be used to identify an individual, including name, address, date of birth, financial details, government-issued identification numbers, or biometric data.
- **MFA (Multi-Factor Authentication):** An authentication method that requires two or more independent verification factors: something you know (password), something you have (hardware token or authenticator app), or something you are (biometric). This significantly reduces the risk of unauthorized account access.
- **Security Incident:** Any event or suspected event that actually or potentially jeopardizes the confidentiality, integrity, or availability of information assets, including unauthorized access, data loss, ransomware, phishing, or suspicious system behaviour.
- **Least Privilege:** The security principle of granting personnel only the minimum access rights and permissions necessary to perform their designated job functions. No additional access is granted unless formally approved.
- **RBAC (Role-Based Access Control):** A method of regulating access to systems and data based on a user's defined organizational role, rather than granting access on an individual, ad hoc basis.

3. Roles & Responsibilities

Security is a shared organizational responsibility. The following roles carry specific obligations under this policy.

3.1 IT Administrator / Security Lead

- Provision and deprovision all user accounts in accordance with this policy, including the mandatory 2-hour offboarding access revocation SLA
- Conduct quarterly access reviews to verify all active accounts remain appropriate and necessary
- Manage, monitor, and maintain security tools, systems, and configurations
- Lead incident identification, containment, investigation, and response
- Maintain version control of this policy and all associated security documentation
- Report confirmed breaches to executive management and coordinate regulatory notification within 72 hours

3.2 Management

- Formally authorize all access requests and role assignments before provisioning is initiated
- Ensure all direct reports complete mandatory annual security awareness training
- Report suspected policy violations or security concerns to the IT Administrator immediately
- Approve or formally reject all exception requests in accordance with Section 10
- Support enforcement of this policy within their respective departments

3.3 Employees

- Read, understand, and comply with all requirements of this policy; sign the acknowledgment block (Appendix A) upon commencement and at each annual review
- Report all suspected security incidents to the IT Administrator within 4 hours of discovery
- Complete annual security awareness training as required
- Protect all company-issued devices, credentials, and Confidential data at all times
- Never share passwords, access credentials, or MFA codes with any other individual

4. Password Policy

4.1 Password Requirements

All user accounts and system credentials must meet the following minimum standards:

- Minimum length of 12 characters
- Must include uppercase letters, lowercase letters, numbers, and at least one special character (e.g., !, @, #, \$)
- Must not contain the user's name, username, company name, or sequential keyboard patterns (e.g., 'qwerty', '12345')
- Common, default, or previously compromised passwords are strictly prohibited

4.2 Password Management

- Arbitrary, time-based password rotation is not required in accordance with NIST SP 800-63B. Passwords must only be changed immediately upon suspected compromise, confirmed breach, or threat intelligence alerts indicating credential exposure.
- Reuse of the last 10 passwords is prohibited
- All employees are required to use a company-approved password manager (e.g., Bitwarden, 1Password) to generate and securely store credentials
- Passwords must never be shared, written on paper, or transmitted via unencrypted email or messaging platforms

NIST SP 800-63B Note: Mandatory periodic password rotation (e.g., every 90 days) has been removed from this policy in alignment with NIST SP 800-63B, which demonstrates that forced rotation leads to weaker passwords (e.g., Password1! → Password2!) without security benefit. Passwords are changed only when compromise is suspected or confirmed.

4.3 Multi-Factor Authentication (MFA)

MFA is mandatory for all accounts accessing company email, financial systems, cloud platforms, and remote access solutions. SMS-based authentication is discouraged due to SIM-swapping vulnerabilities. Hardware tokens or authenticator applications (e.g., Microsoft Authenticator, Google Authenticator) are the approved standard.

5. Access Control

Access to **BTOS Corp.** systems and data is governed by the principle of Least Privilege: personnel are granted only the minimum access necessary to perform their assigned job functions.

5.1 Role-Based Access Control (RBAC)

- System access is assigned based on defined roles, not individual requests
- Administrative privileges are restricted exclusively to authorized IT personnel
- Junior staff and contractors are prohibited from accessing executive financial records, client databases, or core infrastructure settings without documented, time-limited authorization

5.2 User Account Management

- All new employee accounts must be formally requested, approved by a department manager, and provisioned by the IT Administrator
- Access reviews must be conducted every 90 days to verify that all active accounts remain necessary and appropriate
- Upon employee termination, resignation, or contract completion, all system access, credentials, VPN profiles, and physical access rights must be revoked within 2 hours

5.3 Remote Access

- Remote access to company systems is permitted only through an approved Virtual Private Network (VPN)
- Personal devices used for remote work must comply with company endpoint security requirements, including active antivirus software and full-disk encryption
- Unmanaged public Wi-Fi networks must not be used to access company systems without VPN protection

6. Data Protection

BTOs Corp. is committed to protecting the confidentiality and integrity of all information assets, particularly client financial data and personally identifiable information (PII).

6.1 Data Classification

All company data is classified into three tiers:

- Confidential: Client financial records, payroll data, authentication credentials, legal documents, and strategic business plans
- Internal: Internal communications, operational procedures, business strategies, and non-public company data
- Public: Marketing materials, published reports, and website content approved for external distribution

6.2 Data at Rest

- All devices processing Confidential or Internal data must enforce full-disk encryption (BitLocker for Windows, FileVault for macOS)
- Storing Confidential data on personal devices, unauthorized USB drives, or unapproved cloud storage platforms is strictly prohibited
- Physical documents containing Confidential data must be stored in locked cabinets when not in active use

6.3 Data in Transit

- All transmission of Confidential data must occur through AES-256 encrypted channels or approved secure enterprise portals
- Unencrypted email must not be used to transmit financial records, client data, or authentication credentials
- File sharing must be conducted exclusively through company-approved, encrypted platforms

6.4 Data Retention & Disposal

- Data must be retained in accordance with applicable legal and regulatory requirements

- When disposal is required, digital data must be securely wiped using certified data sanitization methods; physical documents must be cross-cut shredded

7. Incident Reporting

All employees are responsible for identifying and promptly reporting potential security incidents to minimize operational impact and ensure regulatory compliance.

7.1 What Constitutes a Security Incident

- Suspected phishing emails, social engineering attempts, or unsolicited requests for credentials
- Unauthorized or suspicious access to company systems or data
- Lost or stolen devices that contain or have accessed company data
- Ransomware, malware detection, or unusual system behaviour
- Accidental disclosure of Confidential data to unauthorized parties

7.2 Reporting Procedure

- All suspected incidents must be reported to the designated Security Lead or IT Administrator within 4 hours of discovery
- Reports must include: the date and time of the incident, systems and data potentially affected, a description of what occurred, and any immediate actions already taken
- Employees must not attempt to independently investigate or remediate a security incident without explicit authorization from the IT Administrator

7.3 Breach Notification

In the event of a confirmed data breach involving client or financial data, affected parties and relevant regulatory authorities will be notified within 72 hours in accordance with applicable data protection regulations. Operations on affected systems will be suspended pending investigation and remediation.

8. Business Continuity & Data Recovery

BTOs Corp. must maintain the ability to recover critical data and resume operations following any disruptive event, including ransomware, hardware failure, or natural disaster.

8.1 Backup Requirements

- All Confidential and Internal data must be backed up on a daily automated schedule
- Backups must cover all critical systems including financial records, client data, email, and operational databases

- Each backup must include a verified integrity check to confirm data completeness and consistency
- Backup logs must be retained and reviewed monthly by the IT Administrator

8.2 Ransomware Protection

- At least one backup copy must be stored in an isolated environment that is physically or logically separated from the primary network - this may be air-gapped offline storage, immutable cloud storage (e.g., AWS S3 Object Lock, Azure Immutable Blob), or an offline tape solution
- Isolated backup storage must be configured as write-once/read-many (WORM) or otherwise protected from modification or deletion by ransomware processes
- Network-attached backup drives that are continuously accessible to company systems do not satisfy this requirement

8.3 Recovery Testing

- A full restoration test must be conducted bi-annually (every 6 months) to verify that backups can be successfully restored within the defined Recovery Time Objective (RTO)
- Test results, including any failures or anomalies, must be documented and reported to management
- Any failed restoration test must trigger an immediate remediation review before the next operational cycle

9. Employee Responsibilities

Every employee plays a critical role in maintaining **BTOs Corp.** security posture. Cybersecurity is not solely the responsibility of the IT department; it is a company-wide obligation.

9.1 General Responsibilities

- All employees must read, understand, and comply with this policy upon commencement of employment and upon each annual policy review
- Employees must complete annual security awareness training as provided or arranged by the company
- Employees must exercise caution when handling emails from unknown senders, clicking hyperlinks, or downloading attachments

9.2 Acceptable Use

- Company-issued devices and systems must be used primarily for legitimate business purposes
- Installation of unauthorized software on company devices is prohibited without prior IT approval

- Accessing inappropriate, illegal, or non-work-related content on company systems is prohibited and may be subject to audit

9.3 Physical Security

- Employees must lock their workstations when stepping away, even briefly (Windows: Win+L; macOS: Cmd+Ctrl+Q)
- Confidential documents must not be left unattended on desks, printers, or in common areas
- Visitors must be escorted at all times within secure areas of the office and must not be left alone with access to company systems

9.4 Policy Acknowledgment

By accessing **BTOs Corp.**'s systems and information assets, all personnel acknowledge that they have read, understood, and agree to comply with this Information Security Policy. Non-compliance may result in disciplinary action up to and including termination of employment or contract.

10. Policy Exceptions

This policy is mandatory for all personnel. Any deviation from the requirements set forth herein must follow the formal exception process below.

- Exception requests must be submitted in writing to the IT Administrator/Security Lead and approved by executive management
- Each request must document: (a) the specific requirement being waived, (b) the business justification, (c) proposed compensating controls to mitigate residual risk, (d) a risk assessment, and (e) an explicit expiration date not exceeding 90 days
- All approved exceptions must be logged in the Exception Register, reviewed at the next annual policy review, and renewed or closed before expiry
- Exceptions do not authorize non-compliance with applicable laws or regulatory requirements

11. Policy Maintenance & Review

This policy will be reviewed and updated on an annual basis to ensure continued relevance and alignment with evolving threats, regulatory requirements, and organizational changes.

- The IT Administrator/Security Lead is responsible for initiating and coordinating the annual review
- An unscheduled review must be triggered immediately following a significant security incident, major organizational restructuring, or a material change in applicable law or regulation

- All revisions must be version-controlled, and each new version must be approved by executive management before distribution to employees
- Employees must acknowledge the updated policy within 30 days of each new version being issued

Document Control

Prepared By	Tauqeer Mustafa Inc.
Version	2.0 - Updated Release
Next Review	05/06/2027
Approved By	Dept. Of CYS - Tauqeer Mustafa Inc.
Contact	contact@tauqeermustafa.tech

Appendix A — Employee Acknowledgment

I acknowledge that I have received, read, and understood the Information Security Policy of **BTOS Corp.**, Version 2.0, effective 05/06/2026

I agree to comply with all requirements set forth in this policy and understand that violations may result in disciplinary action up to and including termination of employment or contract.

Signature	
Print Name	
Job Title	
Department	
Date Signed	
Employee ID	

This document is the intellectual property of Tauqeer Mustafa Inc. and is intended for the exclusive use of the named client organization. Unauthorized distribution is strictly prohibited.